

(c) Narrativa Explicativa de la Encuesta APT

1. Por qué otra encuesta más

La ciberseguridad está ya saturada de informes, índices, gráficos y siglas. Sin embargo, cuando se pregunta a una organización "¿hasta qué punto estás preparada frente a una Amenaza Persistente Avanzada (APT)?", las respuestas suelen oscilar entre el optimismo injustificado y el pesimismo inconfesable.

Esta encuesta nace con una vocación más modesta (y honesta): medir, con cierto rigor y un poco de ironía, qué se está haciendo realmente en las organizaciones españolas para convivir con las APT sin perder el sueño —o al menos durmiendo con un ojo abierto.

2. Qué pretende medir

La encuesta no busca averiguar si la organización ha sido atacada por un grupo con nombre exótico, sino si:

- Existe una gobernanza clara, con una estrategia de ciberseguridad que tenga en cuenta las APT y no solo los incidentes de manual.
- La gestión del riesgo incorpora escenarios APT y se cuantifica su impacto potencial.
- Se utilizan métricas operativas (MTTD, MTTR, MTTP, ratio de phishing, etc.) más allá de contar cuántos correos de spam se han bloqueado.
- Las capacidades de detección se apoyan en marcos como MITRE ATT&CK y en una inteligencia de amenazas que vaya más allá de leer titulares.
- La respuesta y recuperación se prueban y no se dejan a la improvisación heroica del técnico de guardia.
- La cultura y la formación permiten que la APT no entre por la puerta del phishing en el primer correo mínimamente convincente.
- La inversión realizada tiene algún tipo de lógica cuantificable, aunque sea aproximada, y se pueda hablar de ROI sin rubor.

3. Cómo está construida

La encuesta se ha diseñado a partir de:

- Las tendencias identificadas en informes recientes de agencias europeas y españolas, así como de fabricantes de referencia.
- Marcos de referencia ampliamente utilizados (NIST CSF, ISO 27001, NIS2, MITRE ATT&CK, etc.).
- El sentido común de quienes han tenido que explicar a su Consejo de Administración que el ransomware no se elimina con un antivirus "un poco mejor".

Cada bloque busca recoger evidencia observable, no deseos piadosos. De ahí el uso de escalas de madurez (0–3) que obligan a diferenciar entre "lo tenemos escrito en una política" y "lo medimos, lo revisamos y actuamos en consecuencia".

4. Cómo leer los resultados

Los resultados se pueden interpretar en varios niveles:

- Por bloque: para ver si la organización es fuerte en detección pero débil en gobernanza, o viceversa.
- Por indicador: para identificar agujeros concretos (por ejemplo, gestión de vulnerabilidades razonable, pero cero métricas de MTTR).
- Globalmente: mediante el Índice Global de Madurez (IGM), que condensa la situación en un número entre 0 y 1.

La idea no es obtener un "sello" de madurez perfecta, sino disponer de una brújula cuantitativa: saber si se avanza, se retrocede o se gira en círculos.

5. Qué NO es esta encuesta

- No es una auditoría formal ni sustituye a una certificación.
- No es un test de intrusión ni un informe forense.
- No es un examen de conocimientos para humillar a nadie en público.

Es una herramienta de autoevaluación y análisis comparado. Si al rellenarla aparecen preguntas incómodas, probablemente la encuesta esté cumpliendo su función.

6. Usos recomendados

- A nivel interno: como base para talleres con la alta dirección, comités de riesgo o equipos de TI y seguridad.
- A nivel sectorial: para estudios comparativos, informes anuales y benchmarking entre organizaciones similares.
- A nivel nacional: para alimentar análisis agregados sobre el estado de la madurez frente a APT en España y orientar políticas públicas.

Idealmente, la encuesta no debería quedarse en un PDF olvidado, sino integrarse en un ciclo periódico de medición (anual, bienal) que permita ver tendencias, no solo fotografías estáticas.

7. Epílogo

Si esta encuesta consigue que al menos una organización:

- Deje de considerar la ciberseguridad como un mero coste obligatorio.
- Empiece a medir algo más que el número de incidencias abiertas en el helpdesk.
- Y logre que su próxima conversación sobre APT con el Consejo de Administración incluya números y no solo adjetivos.

Entonces, el tiempo invertido en diseñarla habrá estado razonablemente bien empleado.